Analyse du Rooting Android

Laboratoire de Sécurité Mobile

Cours : Sécurité des applications mobiles

Auteur : Omar Haouani

Environnement : Android Virtual Device (AVD)

Date : 28 mars 2026

Table des matières

1 Introduction **2**

2 Configuration de l'environnement de test **2**
2.1 Vérification de la connectivité 2

3 Obtention des privilèges administrateur **2**

4 Déploiement de l'application cible **2**

5 Cas de test fonctionnels **4**
5.1 Scénario 1 - Accès à l'interface 4
5.2 Scénario 2 - Saisie et soumission 4
5.3 Scénario 3 - Traitement des données 4

6 Fondamentaux de la sécurité Android **4**

7 Mécanismes de vérification au démarrage **4**
7.1 Verified Boot 4

8 Définition du rooting **5**

9 Analyse des risques opérationnels **6**

10 Référentiels OWASP **6**
10.1 Exigence STORAGE-1 6
10.2 Exigence NETWORK-1 6
10.3 Tests MASTG 6

11 Nettoyage et remise à zéro **6**

12 Synthèse des commandes **6**

13 Checklist **7**

14 Ressources **7**

1 Introduction

Ce travail pratique examine l'impact du rooting sur l'écosystème Android.
Règles de conduite :

- Utilisation exclusive d'un environnement de test dédié
- Données factices uniquement
- Aucune interaction avec des systèmes externes

2 Configuration de l'environnement de test

Élément	Détail
Type d'environnement	Android Virtual Device (AVD)
Appareil simulé	Pixel 6
Version système	Android 36 (API 36)
Architecture	Google APIs x86_64
Instance	rooted_avd

2.1 Vérification de la connectivité

```
adb devices
```

Résultat : `emulator-5554 device`

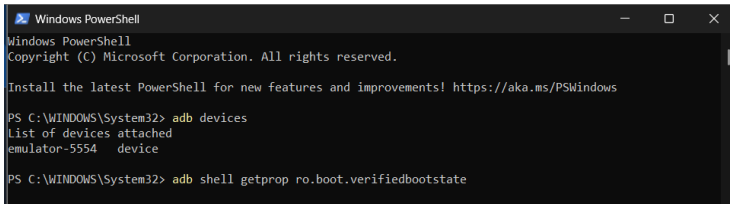

FIGURE 1 – Connexion ADB

3 Obtention des privilèges administrateur

```
adb shell id
adb shell getprop ro.boot.verifiedbootstate
adb shell getprop ro.boot.veritymode
adb shell getprop ro.boot.vbmeta.device_state
```

4 Déploiement de l'application cible

L'application testée présente un formulaire avec les champs suivants :

- Identité (Nom et prénom)

Commande	Résultat
adb shell id	uid=0(root) gid=0(root)
ro.boot.verifiedbootstate	enforcing
ro.boot.veritymode	enforcing
ro.boot.vbmeta.device_state	enforcing

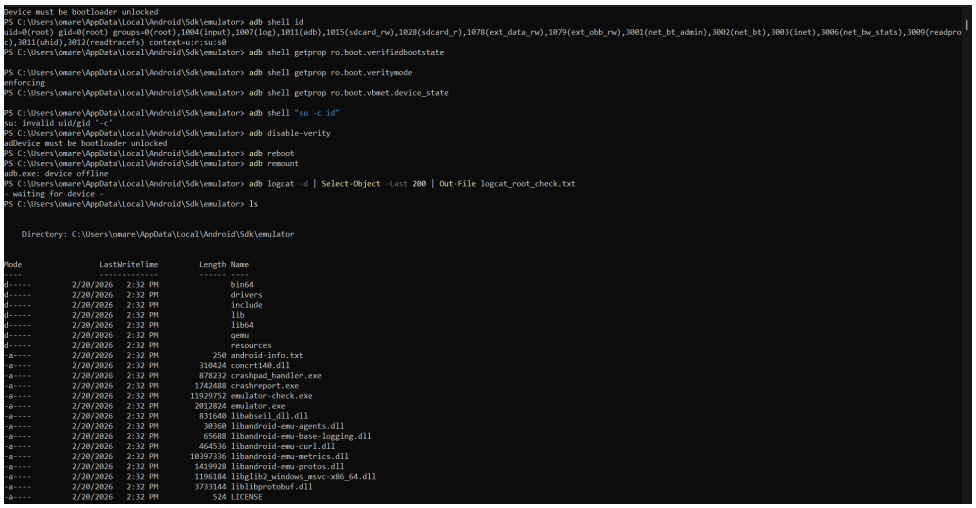

FIGURE 2 – Commandes ADB Root

— Adresse électronique
— Numéro de téléphone
— Adresse postale
— Localité

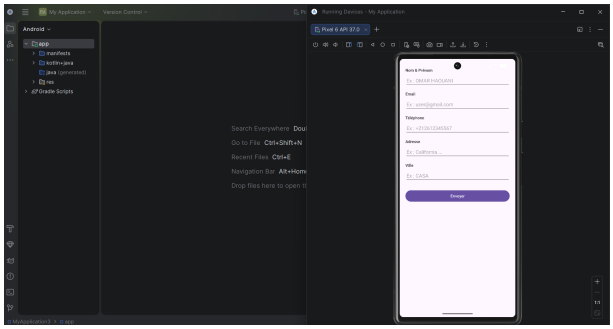

FIGURE 3 – Formulaire vierge

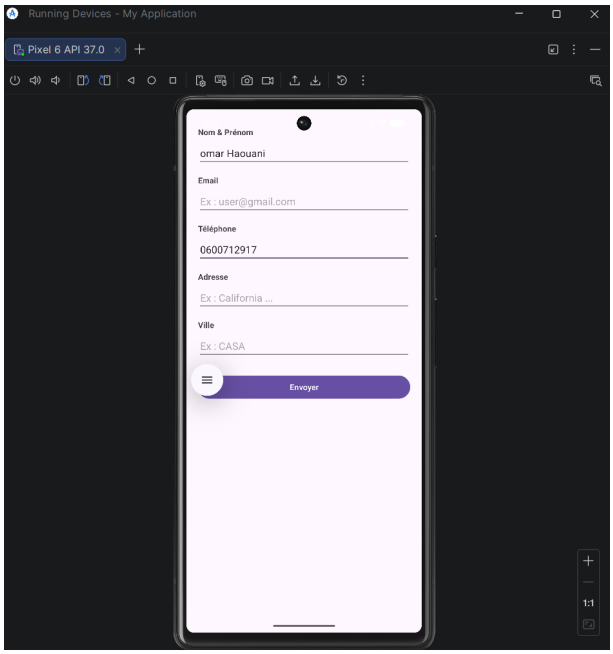

FIGURE 4 – Formulaire pré-rempli

5 Cas de test fonctionnels

5.1 Scénario 1 - Accès à l'interface

L'application se lance et affiche le formulaire sans erreur.

5.2 Scénario 2 - Saisie et soumission

Saisie des données : **Omar Haouani**, **0600712917**.

5.3 Scénario 3 - Traitement des données

Le système traite la soumission sans anomalie.

6 Fondamentaux de la sécurité Android

1. **Isolation applicative** : chaque application évolue dans un espace confiné.
2. **Gestion des autorisations** : accès aux ressources sensibles validé par l'utilisateur.
3. **Protection du noyau** : préservation de l'intégrité des composants critiques.

L'obtention des droits root neutralise ces trois mécanismes.

7 Mécanismes de vérification au démarrage

7.1 Verified Boot

Garantit que le système exécuté correspond à la version originale.

```
adb shell getprop ro.boot.verifiedbootstate
# enforcing
```

```
fastboot getvar avb_boot_state
```

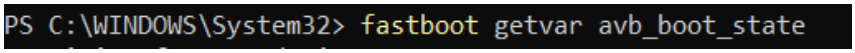

FIGURE 5 – Vérification Fastboot

8 Définition du rooting

Le rooting consiste à acquérir les droits super-utilisateur (uid=0). Cette action modifie le modèle de sécurité en désactivant l'isolation applicative et le contrôle des permissions. En laboratoire, cette configuration permet d'analyser le comportement interne des applications. Une remise à l'état initial est impérative après chaque session.

9 Analyse des risques opérationnels

N°	Risque	Conséquence
1	Altération de l'intégrité système	Résultats non représentatifs
2	Augmentation surface d'attaque	Exposition à des menaces externes
3	Exposition de données sensibles	Violation de confidentialité
4	Instabilité fonctionnelle	Tests non reproductibles
5	Mixage comptes personnel/test	Fuite d'informations
6	Nettoyage incomplet	Persistance de données
7	Absence d'isolation réseau	Interactions involontaires
8	Traçabilité insuffisante	Non-reproductibilité

10 Référentiels OWASP

10.1 Exigence STORAGE-1

Les informations sensibles doivent être protégées par chiffrement. Stockage en clair interdit.

10.2 Exigence NETWORK-1

Les échanges doivent utiliser TLS avec validation des certificats.

10.3 Tests MASTG

```
adb shell ls /data/data/ma.ens.myapplication/
adb shell cat /data/data/ma.ens.myapplication/files/
   profileInstalled
adb logcat -d | Select-Object -Last 100 | Out-File logcat_mastg.txt
```

11 Nettoyage et remise à zéro

```
adb emu avd stop
adb emu avd wipe-data
```

12 Synthèse des commandes

```
adb devices                                # V rification connexion
adb shell id                               # V rification
   privil ges
adb shell getprop ro.boot.verifiedbootstate  #  tat  Verified Boot
fastboot getvar avb_boot_state               #  tat  AVB
adb emu avd wipe-data                        # Nettoyage complet
```

```
PS C:\WINDOWS\System32> adb emu avd stop
OK
PS C:\WINDOWS\System32> adb emu avd wipe-data
allows you to control (e.g. start/stop) the execution of the virtual device

available sub-commands:
    stop            stop the virtual device
    start           start/restart the virtual device
    status          query virtual device status
    heartbeat       query the heart beat number of the guest system
    rewindaudio     rewind the input audio to the beginning
    name            query virtual device name
    grpc            query the grpc port
    snapshot        state snapshot commands
    pause           pause the virtual device
    hostmicon       activate the host audio input device
    hostmicoff      deactivate the host audio input device
    resume          resume the virtual device
    bugreport       generate bug report info.
    id              query virtual device ID
    windowtype      query virtual device headless or qtwindow
    path            query AVD path
    discoverypath   query AVD discovery path
    snapshotspath   query AVD snapshots path
    snapshotpath    query path to a particular AVD snapshot

KO:  bad sub-command
PS C:\WINDOWS\System32>
```

FIGURE 6 – Commandes de nettoyage

13 Checklist

Avant intervention

- x Périmètre d'action documenté
- x Instance AVD dédiée créée
- x Application test installée
- x Scénarios définis

Après intervention

- x Remise à zéro effectuée
- x Traces conservées
- x Rapport sauvegardé
- x Absence de comptes personnels

14 Ressources

- Documentation sécurité Android
- Verified Boot
- OWASP MASVS
- OWASP MASTG

Document réalisé dans le cadre du cours de Sécurité des applications mobiles
Omar Haouani - 2026